

# Carremax Cyber Risk Quantification (CRQ) Dashboard

Executive Risk Assessment & Investment Prioritization | FAIR Monte Carlo (10,000 Iterations)

PAGE 1: RISK QUANTIFICATION

Crown Jewels: ERP & Supply Chain Logistics

BASELINE 90% VAR

**€88.0M**

Critical: Exceeds €50M Limit

APPETITE EXCEEDANCE

**27.8%**

P(Loss > €50M Appetite)

BASELINE NET AEL

**€29.5M**

Annualized Expected Loss

MITIGATED 90% VAR

**€25.0M**

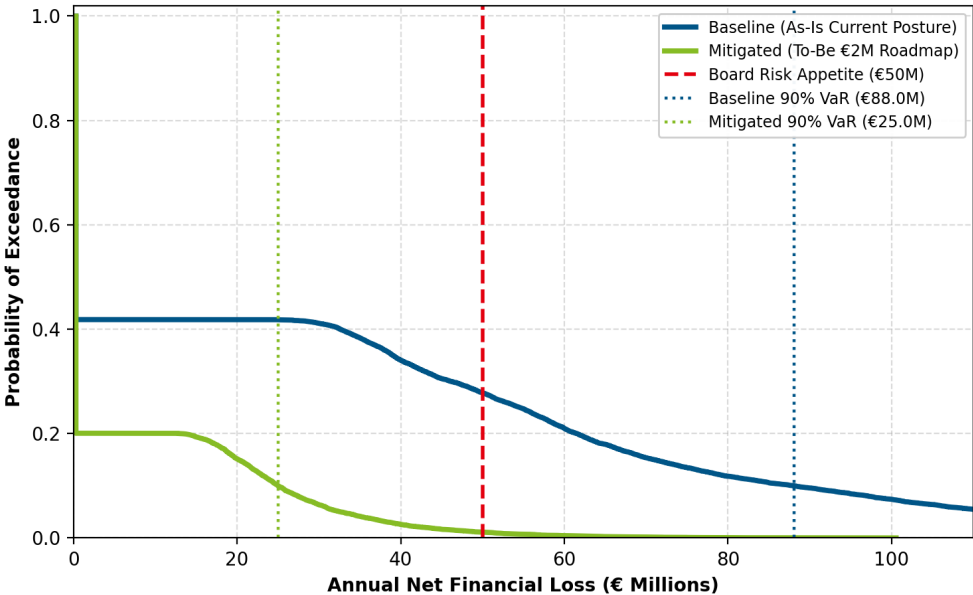
Within Risk Appetite (< €50M)

ROSI ON €2M PROJECT

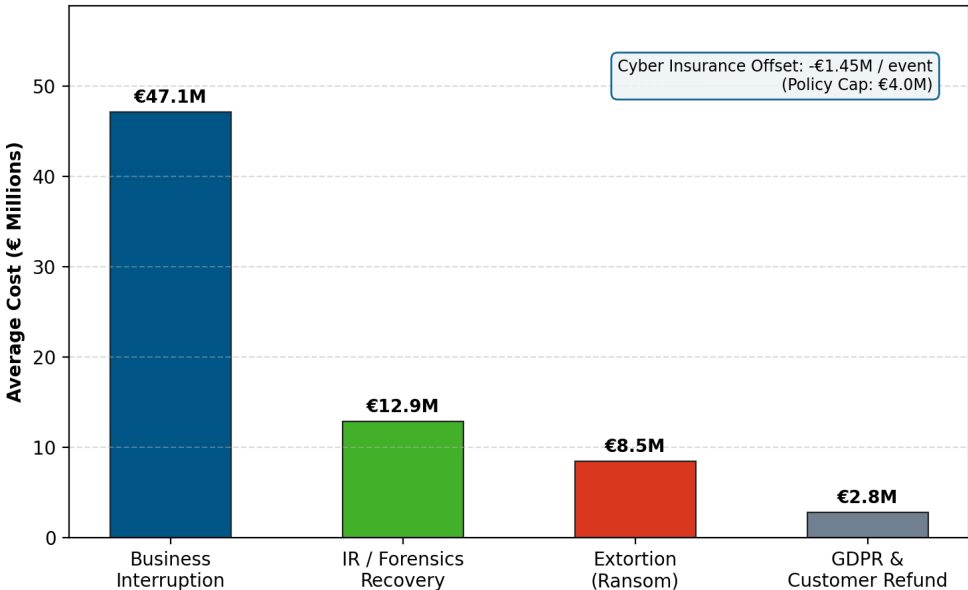
**1082%**

Net ΔAEL: €23.6M/yr

Loss Exceedance Curve (LEC) - 10,000 Iterations



Baseline Loss Breakdown (Avg. per Breach Event)



## 1. CURRENT RISK POSTURE (AS-IS BASELINE)

**CRITICAL RISK VIOLATION:** The baseline 90% VaR of **€88.0M** severely breaches the Board's **€50M Risk Appetite**. There is a **27.8% annual probability** of experiencing catastrophic loss.

• **Root Cause:** 90% EDR leaves a 10% server blind spot, 0% OT visibility, and manual IR processes that delay full recovery to an average of **2.9 weeks** (surpassing the 2-week backup threshold).

## 2. MITIGATED RISK POSTURE (€2M INVESTMENT)

**BOARD RISK COMPLIANCE ACHIEVED:** With the €2M automation & OT defense initiative, 90% VaR drops to **€25.0M**, and appetite exceedance probability plunges from **27.8% to 1.1%**.

• **High Return on Investment:** Reduces expected annual losses by **€23.6M/year**, delivering a **1082% ROSI** and returning net positive value within the first quarter of deployment.

**Model Governance:** Monte Carlo simulation based on Open FAIR™ Standard (ISO/IEC 27005 compliant). 10,000 iterations executed with random seed 42. Gross loss includes Business Interruption, IR & Forensics, Extortion/Ransom, and GDPR/Refunds net of insurance recovery.

# Carremax Cyber Risk Quantification (CRQ) - Strategic Roadmap

Detailed FAIR Decomposition, Cyber Insurance Optimization & Board Decision Matrix

## FAIR PARAMETER DECOMPOSITION & MODELING CALIBRATION

| FAIR Factor                        | Parameter Range (Min / Mode / Max)             | Expert Elicitation & Operational Rationale                                                                          |
|------------------------------------|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| Threat Event Frequency (TEF)       | PERT(1.0, 1.5, 2.0) attempts / year            | Calibrated against Cyentia IRIS 2025 retail sector baseline and peer group benchmarks (2 attacks in 3 years).       |
| Vulnerability (Vuln)               | PERT(15%, 35%, 60%)                            | 90% EDR coverage provides baseline defense, but 10% server gap and 0% OT visibility enable lateral threat movement. |
| Downtime Duration                  | PERT(1.0, 2.0, 4.5) weeks                      | Backups support degraded operations up to 2 weeks; manual IR recovery bottlenecks cause severe outage extensions.   |
| Primary Loss: Downtime (BI)        | Non-linear: €15M/1w, €30M/2w, €50M/3w, €90M/4w | Reflects high operational reliance on ERP and supply chain for both physical stores (70%) and e-commerce (30%).     |
| Primary Loss: IR & Forensics       | PERT(€5.0M, €10.0M, €15.0M)                    | Direct external incident response, digital forensics, crisis communication, and core infrastructure rebuild costs.  |
| Secondary Loss: Extortion (Ransom) | Willingness Capped at €20.0M                   | Executive committee strictly caps ransom payout; model activates extortion negotiation if downtime exceeds 2 weeks. |
| Secondary Loss: GDPR & Refunds     | PERT(€0M, €2.0M, €5.0M)                        | CNIL regulatory reporting, minor legal friction, customer compensation, and e-commerce conversion refunds.          |
| Financial Offset: Cyber Insurance  | €500k/week (Max Cap: €4.0M / 8 weeks)          | Policy holds €300k annual premium; pays out an average of €1.45M during qualified breach events.                    |

## CYBER INSURANCE GAP ANALYSIS

- **Current Policy Limits:** €300k annual premium for €500k/week BI coverage, strictly capped at 8 weeks (€4.0M total payout).
- **Underinsurance Exposure:** Average single-event gross loss is **€69.8M**, meaning the insurance policy absorbs only **~2-4%** of severe outage losses.
- **Recommendation:** In parallel with technical mitigation, renegotiate the cyber insurance policy to raise the BI sub-limit and total payout cap to **€25M–€30M**.

## PRIORITIZED BOARD ACTION PLAN

- 1. Approve €2M Security Automation CapEx/OpEx:** Immediate deployment of automated IR containment and recovery playbooks to compress recovery time from ~3 weeks to < 1 week.
- 2. Eliminate 10% IT Blind Spot & Implement OT Visibility:** Mandate 100% EDR coverage and deploy passive OT network monitoring in supply chain distribution hubs.
- 3. Validate Backup Recovery in Zero-Trust Drills:** Test cold ERP recovery quarterly to guarantee degraded operation viability within the €50M Risk Appetite.

**Decision Summary:** Executive authorization of the €2M cybersecurity roadmap is strongly recommended. It directly remediates the board's €50M risk appetite breach, achieves a 1,082% ROSI, and preserves the operational integrity of Carremax's ERP and logistics crown jewels.